

Questions reponses jury - Yvan

Questions / reponses jury - Yvan FOCSA

Pourquoi seulement trois sites simules alors que le cahier des charges parle d'environ 30 points de vente ?

Parce que le projet est un MVP. L'objectif n'est pas de reproduire tout le parc, mais de prouver un modele representatif. Trois sites suffisent pour montrer la collecte multi-source, les dashboards par site et l'industrialisation vers un nombre plus important de centres.

Pourquoi avoir choisi Wazuh ?

Wazuh est open-source, centralise, dispose d'agents, d'une interface web, d'un moteur de regles et d'une integration avec OpenSearch. Il repond donc bien aux attentes : SIEM centralise, alertes personnalisables, dashboards et solution reproductible.

Docker est-il adapte a une production ?

Non, Docker est surtout adapte au demonstrateur. Pour une production, on prevoirait des actifs reels : postes avec agents, serveurs internes, firewall ou pfSense, haute disponibilite, sauvegarde et politique de retention. Docker permet ici de rendre le MVP plus leger et reproductible.

Quel firewall utilisez-vous pour syslog ?

Le choix concret cible est pfSense CE. Dans le MVP, les firewalls sont representes par FW-S01 et FW-S02, avec des logs syslog simules dans etape 1/logs/generated/firewall_syslog.log. En production, chaque centre aurait un firewall pfSense CE ou un equipement equivalent qui exporte ses logs vers Wazuh via syslog, idealement dans un tunnel VPN et avec filtrage par IP source.

Comment passer de 3 sites simules a 30 sites reels ?

Il faut standardiser l'onboarding : inventaire site, convention de nommage, package agent, configuration syslog, test d'alerte, validation dashboard et reporting. C'est pour cela que le projet contient une checklist d'onboarding et un exemple d'inventaire.

Quelles sont les principales limites ?

Les logs sont simules ou rejoues, le SOC n'est pas exploite 24/7, la haute disponibilite n'est pas mise en place, et certaines integrations seraient a renforcer en production. Ces limites sont assumees car le projet vise un demonstrateur fonctionnel et documente.

Quelle est ta contribution personnelle ?

J'ai contribue au cadrage du besoin, a l'architecture SOC externalisee, a la definition du perimetre MVP, aux flux de collecte, a la logique d'industrialisation, a la documentation et a la coherence entre cahier des charges, rapport, preuves et video.

Comment prouvez-vous que le projet est coherent avec le cahier des charges ?

La matrice de conformite relie chaque exigence a une reponse projet : SIEM open-source, collecte multi-source, dashboards, alertes, playbooks, interface web, reproductibilite et guide de deploiement.

Quelles evolutions recommanderais-tu ?

Ajouter des agents reels sur VMs, integrer Suricata pour la detection reseau, ajouter TheHive ou Shuffle pour le ticketing et l'automatisation, mettre en place du RBAC avance et dimensionner une architecture haute disponibilite.